Firewall

Description

Firewall: Definizione e Funzionamento

Un **firewall** è un dispositivo di rete che agisce come barriera tra due reti, di solito separando una rete interna (più sicura) da una rete esterna (come Internet). Il suo scopo principale è quello di **controllare e filtrare** il traffico in entrata e in uscita tra queste reti, in base a una politica di sicurezza definita. Il firewall agisce come un punto di controllo centrale, **filtrando pacchetti** e **bloccando comunicazioni indesiderate** per proteggere la rete interna da accessi non autorizzati, attacchi e altre minacce.

Principali Caratteristiche del Firewall

Un firewall può essere visto come un modulo che **controlla e limita le comunicazioni** tra moduli o reti. Viene usato principalmente in due modalità:

- **Modalità perimetrale**: Quando il firewall è utilizzato per difendere la rete interna da accessi non autorizzati provenienti dall'esterno (ad esempio, tra la rete aziendale e Internet). In questo caso, basta un firewall (eventualmente ridondato per garantirne la disponibilità).
- **Modalità strutturale**: Quando il firewall viene utilizzato per segmentare una rete interna in **sottoreti separate** in base alla criticità delle informazioni trattate. Questo è un approccio che si adatta al modello di **"defense in depth"**, in cui ogni sezione della rete è protetta da un firewall.

Firewall: Un Modulo per Controllare le Comunicazioni

Un firewall agisce come un **modulo di controllo** che decide non solo **come** raggiungere un determinato nodo, ma anche **se** il mittente ha il permesso di comunicare con quel nodo. Pertanto, integra il routing per filtrare e **validare** i pacchetti, non solo decidendo il percorso ma anche controllando se la comunicazione è autorizzata.

Caratteristiche dei Firewall

Un firewall può essere descritto attraverso due **caratteristiche ortogonali**:

1. **I protocolli che conosce e che filtra**: Determinano il tipo di controllo che il firewall deve implementare.
2. **La sua implementazione**: Determina la robustezza del firewall, cioè come il firewall effettivamente filtra e gestisce i pacchetti in entrata e in uscita.

Punti Critici del Firewall

- **Collo di bottiglia per le prestazioni**: Poiché il firewall centralizza il traffico tra due reti, potrebbe diventare un **collo di bottiglia** se il volume di traffico è troppo alto o se non è adeguatamente dimensionato.
- **Non può controllare le linee che non lo attraversano**: Un firewall non ha alcun controllo sul traffico che bypassa la rete che protegge, per esempio, il traffico che non attraversa la sua "frontiera" (ad esempio, reti interne isolate).

Livelli di Filtraggio dei Firewall

Il firewall può operare a **diversi livelli** del modello di rete, come segue:

1. Firewall a livello 3 (IP packet inspection)

- **Controlla l'header del pacchetto** IP. È simile a ciò che fanno i **router** e può operare su:
  - **Mittente** (indirizzo IP di origine)
  - **Destinatario** (indirizzo IP di destinazione)
  - **Porte** (porta sorgente e destinazione)
  - **Protocollo** (ad esempio, TCP, UDP, ICMP)
  - **Origine della connessione** (per protocollo di livello 4)
- È un tipo di firewall piuttosto semplice che **non analizza il contenuto del pacchetto**, ma solo i metadati dell'header.

2. Firewall a livello 4 (TCP/UDP - Circuit level gateway)

- Opera al **livello di connessione** e controlla **connessioni TCP** o **connessioni UDP**. Può eseguire un controllo più sofisticato, come:

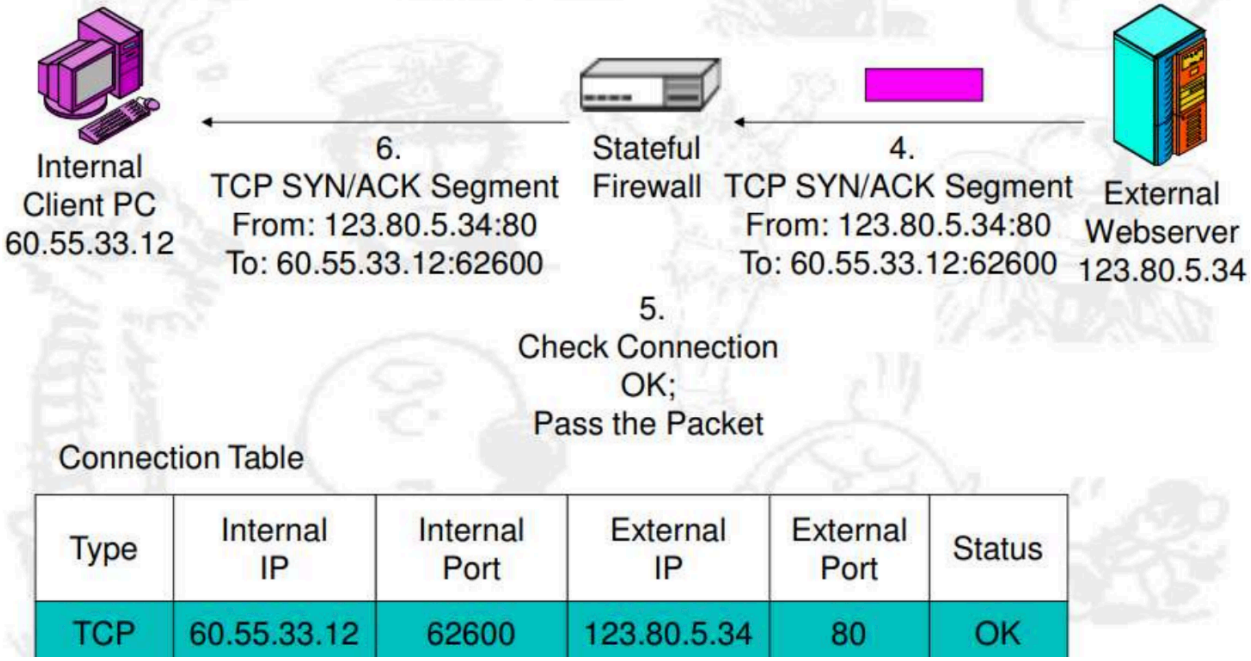
    - Verificare che la connessione sia **legittima** (ad esempio, che il TCP handshake sia stato completato correttamente).
    - **Controllo dello stato**: Il firewall può mantenere informazioni di stato delle connessioni in corso, come un **session state** o una **tabella di connessioni virtuali**, che aiuta a garantire che i pacchetti passino solo se fanno parte di una connessione valida.
    - **Stateful inspection**: Analizza il contesto della connessione per determinare se il traffico è valido.
    - Impedisce che pacchetti vengano inoltrati finché la connessione non è stata **verificata come sicura**.

3. Firewall di livello superiore (Application Layer)

- Questi firewall sono più complessi e operano **a livello di applicazione**. Sono in grado di esaminare **il contenuto del traffico** per scoprire e bloccare attacchi che sfruttano vulnerabilità specifiche dei protocolli applicativi.
- Sono più efficaci contro attacchi complessi come:
    - **SQL injection**
    - **Cross-site scripting (XSS)**
    - **Attacchi di tipo buffer overflow** che possono sfruttare le vulnerabilità nei protocolli applicativi.
- Esempi di firewall di questo tipo includono i **web application firewall** (WAF).

Circuit Level Gateway (Firewall a livello di circuito)

Un **circuit level gateway** (o firewall a livello di circuito) è un tipo di firewall che si concentra sul controllo delle **connessioni TCP**:

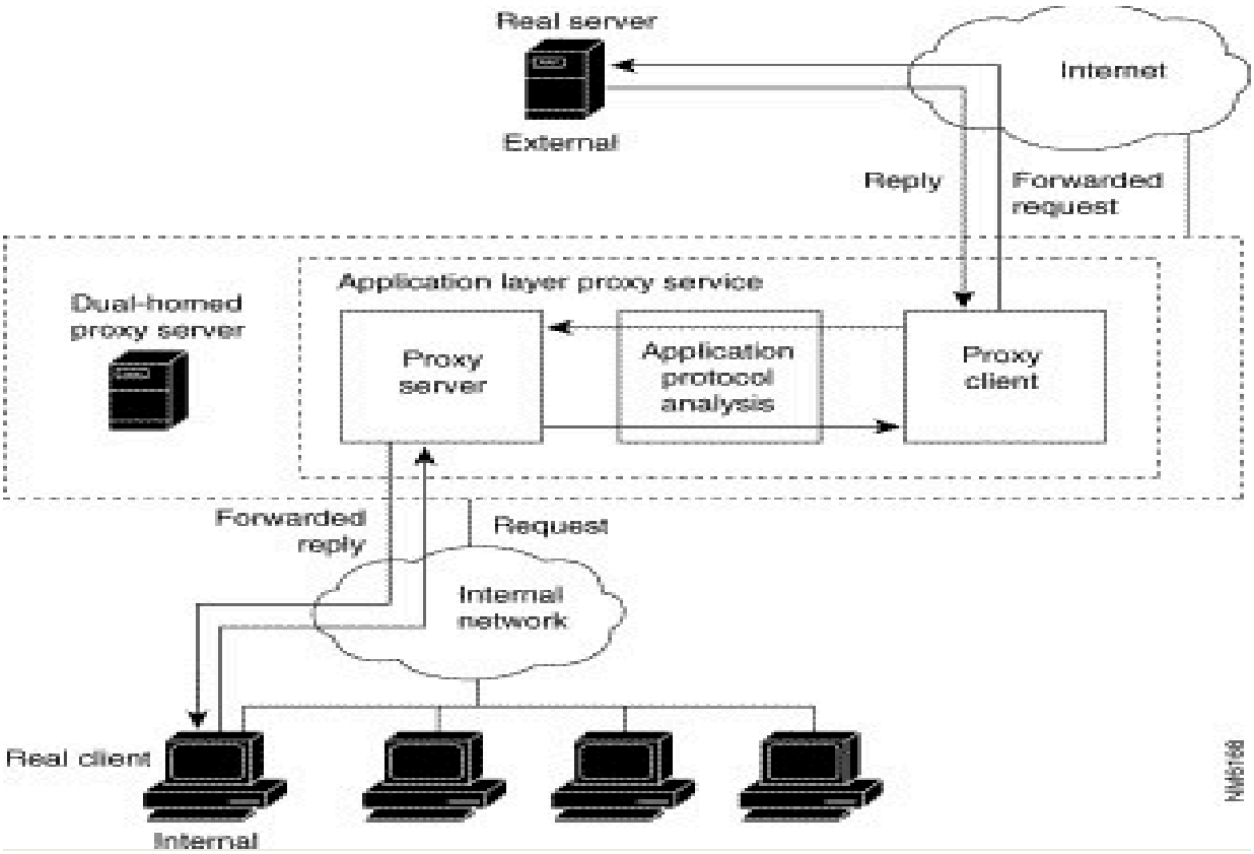


Connection Table

Type	Internal IP	Internal Port	External IP	External Port	Status
TCP	60.55.33.12	62600	123.80.5.34	80	OK

- **Validazione della connessione**: Verifica che una connessione sia **legittima**, cioè che sia stata stabilita correttamente tramite il **TCP handshake** (la negoziazione iniziale di una connessione TCP).
- **Virtual circuit**: Una volta stabilita la connessione, il firewall mantiene una **tabella di circuiti virtuali**, in cui sono memorizzate informazioni come:
  - La **sequenza dei pacchetti**
  - Lo **stato della sessione** (connessione aperta, chiusa, etc.)
  - Gli **indirizzi IP** coinvolti nella connessione.

  Durante il traffico, il firewall confronta i pacchetti con la sua tabella e consente solo quelli che corrispondono a una connessione già stabilita. Una volta che la connessione termina, la voce corrispondente nella tabella viene rimossa.
- **Mascheramento del gateway**: I pacchetti che attraversano il firewall potrebbero sembrare provenire direttamente dal firewall (e non dalla macchina che ha originato il traffico). Questo **mascheramento** può essere utile per nascondere informazioni sensibili sulla rete interna.



Vantaggi rispetto al packet filtering:

- Il **circuit level gateway** offre una protezione più avanzata rispetto al filtraggio dei pacchetti (a livello 3), poiché è in grado di:
  - **Controllare la legittimità** della connessione prima di permettere il passaggio dei pacchetti.
  - Evitare attacchi come **IP spoofing** (falsificazione degli indirizzi IP), che sono più facili da realizzare nel filtraggio dei pacchetti.
  - Ridurre l'efficacia degli **attacchi UDP**, come quelli che sfruttano il **UDP hole punching** (tecnica che permette il passaggio del traffico attraverso il firewall UDP).

Forward Proxy vs Reverse Proxy

I **proxy** sono dispositivi o software che fungono da intermediari tra il client e il server, ma con ruoli diversi a seconda che si tratti di un **forward proxy** o di un

reverse proxy.

Forward Proxy:

- **Funzione principale**: Protegge i client interni da attacchi provenienti dall'esterno.
- **Come funziona**: Il **forward proxy** si posiziona tra i client e Internet. I client inviano le loro richieste al proxy, che poi inoltra queste richieste ai server esterni. Questo tipo di proxy è utile per monitorare e filtrare il traffico in uscita dalla rete interna, bloccare contenuti dannosi e applicare politiche di sicurezza come l'accesso a determinati siti o risorse.
- **Uso tipico**: I forward proxy vengono utilizzati per **controllare l'accesso dei client interni** alla rete esterna (Internet), nascondendo l'identità dei client e proteggendo la rete interna da potenziali minacce.

Reverse Proxy:

- **Funzione principale**: Protegge i server interni da attacchi provenienti dai client esterni.
- **Come funziona**: Il **reverse proxy** si posiziona tra i client esterni e i server interni. I client inviano le loro richieste al reverse proxy, che poi le inoltra al server interno appropriato. Il reverse proxy si presenta come l'interfaccia principale del server interno e nasconde la sua vera architettura, proteggendo così i server interni da attacchi diretti.
- **Funzione aggiuntiva**: Un reverse proxy può anche fungere da **bilanciatore di carico (load balancer)**, distribuendo il traffico su più server per gestire meglio il carico e migliorare le performance.
- **Uso tipico**: I reverse proxy vengono utilizzati per **proteggere i server aziendali** da attacchi esterni, nascondendo l'infrastruttura e, se necessario, distribuendo il traffico su più server.

Stateful Firewall

I **firewall stateful** sono tecnologie che operano a livello di rete per implementare capacità di filtraggio dinamico dei pacchetti. A differenza dei firewall "stateless", che analizzano i pacchetti in modo indipendente, i **firewall stateful** tengono

traccia dello stato delle connessioni e possono determinare se un pacchetto fa parte di una connessione legittima.

Come Funziona un Stateful Firewall:

1. **Monitoraggio delle connessioni**: Un firewall stateful tiene traccia di tutte le sessioni che attraversano la sua interfaccia, mantenendo una **tabella di stato** che memorizza le informazioni relative alle connessioni attive (come IP, porte, stato di connessione, ecc.).
2. **Ispezione dei pacchetti**: I pacchetti che passano attraverso il firewall vengono confrontati con la tabella di stato. Se le caratteristiche del pacchetto corrispondono a quelle previste nella tabella (ad esempio, il pacchetto è parte di una connessione legittima), il firewall consente al pacchetto di passare.
3. **Dinamica della tabella di stato**: La tabella di stato si aggiorna dinamicamente in base al flusso del traffico, quindi il firewall "ricorda" le connessioni passate e le loro proprietà.
4. **Protezione da attacchi comuni**: Poiché i firewall stateful tracciano lo stato delle connessioni, possono proteggere meglio da attacchi come il **SYN flood**, **DoS** (Denial of Service) e altre minacce che sfruttano la manipolazione dei pacchetti.

Funzionalità aggiuntive degli Stateful Firewalls:

- **Logging dello stato TCP**: Gli eventi di ispezione stateful TCP possono essere registrati, permettendo di monitorare e analizzare il traffico.
- **Limitazione delle connessioni**: I firewall stateful possono limitare il numero di connessioni in ingresso e in uscita da un singolo client, riducendo l'impatto di attacchi **DoS** o **exfiltration**.
- **Limitazione delle connessioni half-open**: I firewall possono limitare il numero di connessioni half-open (in attesa di completamento del handshake TCP), proteggendo dai **SYN flood**.
- **Protezione dagli attacchi ACK Storm**: I firewall possono rilevare e bloccare gli attacchi in cui il traffico ACK (acknowledgement) diventa eccessivo, potenzialmente causando congestione.

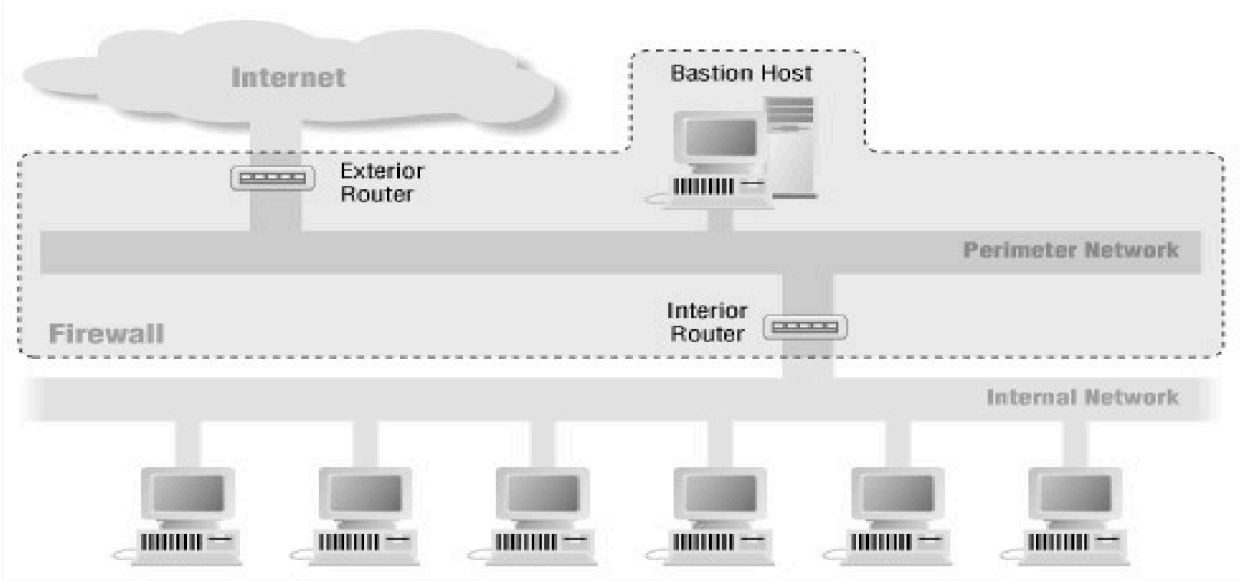
Stateful Inspection per UDP e ICMP:

- **UDP**: Gli stateful firewall possono tracciare il flusso dei pacchetti UDP e consentire solo risposte che avvengono entro un determinato intervallo di tempo (ad esempio, 60 secondi) rispetto alla richiesta originale.
- **ICMP**: Gli stateful firewall possono anche tracciare il traffico ICMP (ad esempio, le risposte ai ping) e permettere solo le risposte in arrivo che corrispondono a una richiesta già inviata.

Next-Generation Firewall (NGFW)

Un **Next-Generation Firewall (NGFW)** è una versione avanzata di un firewall che combina **ispezione dei pacchetti** e **ispezione stateful** con altre funzionalità come la **Deep Packet Inspection (DPI)**, il **Network Intrusion Detection System (IDS)** e il **malware filtering**.

- **Deep Packet Inspection (DPI)**: Mentre i firewall tradizionali esaminano solo l'header del pacchetto (protocollo, indirizzo IP, porta), i **DPI firewall** esaminano anche i **dati reali** trasportati dal pacchetto. Questo consente di rilevare attacchi che sfruttano vulnerabilità nei **dati** (ad esempio, codice malevolo nascosto nei dati di una risposta HTTP).
- **Monitoraggio delle sessioni web**: Un DPI firewall può tracciare il **flusso di sessioni web**, identificando se un payload (ad esempio una risposta HTTP) costituisce una risposta HTML legittima.
- **Costi più elevati**: I NGFW tendono ad essere più costosi rispetto ai firewall tradizionali, poiché combinano una serie di funzionalità avanzate, e quindi richiedono una gestione e configurazione più complessa.



NAT Firewall e IPv6

NAT (Network Address Translation) è una tecnica utilizzata dai firewall per mappare gli indirizzi IP di una rete privata su un singolo indirizzo pubblico. In pratica, permette a più dispositivi di una rete locale (LAN) di condividere lo stesso indirizzo IP pubblico quando accedono a Internet.

Questo è particolarmente utile nel contesto di IPv4, dove c'è una limitata disponibilità di indirizzi pubblici. Con NAT, i dispositivi interni (che usano indirizzi IP privati) possono comunicare con l'esterno tramite un singolo indirizzo IP pubblico.

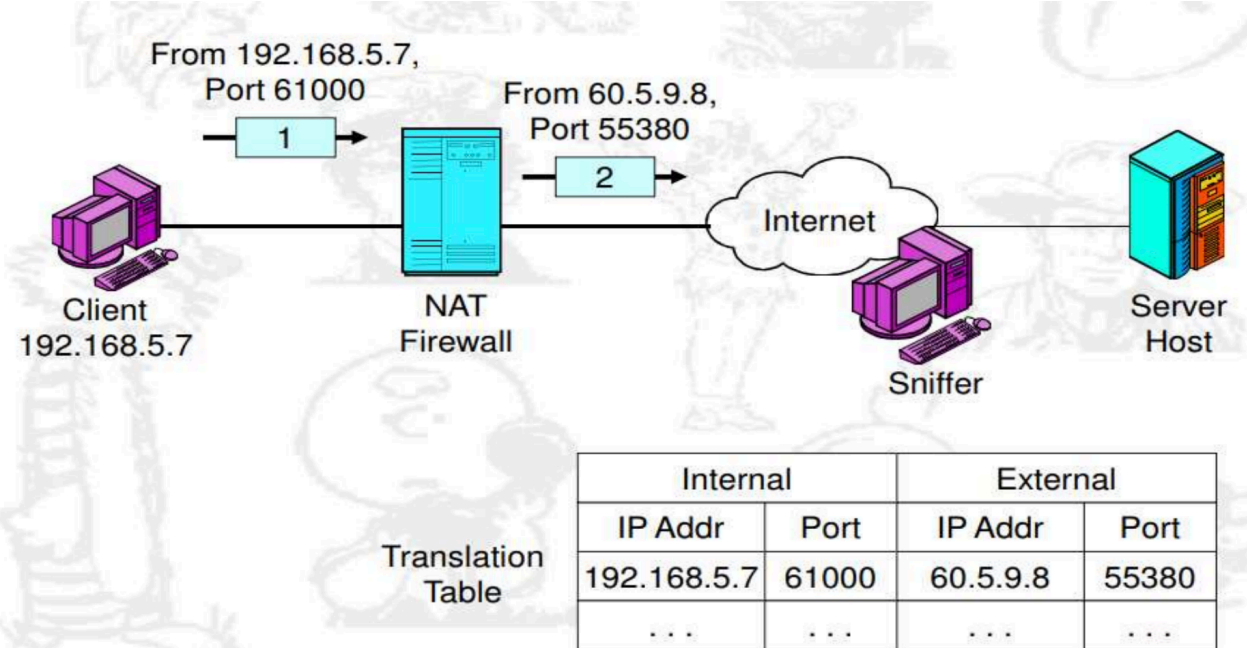
Problema con IPv4 e NAT

Nel contesto di **IPv4**, gli indirizzi IP sono limitati e, per questa ragione, si è reso necessario l'uso di NAT. Con IPv4, l'indirizzo IP pubblico che un dispositivo interno utilizza per comunicare con Internet non è univoco per ciascun dispositivo. Piuttosto, tutti i dispositivi possono condividere lo stesso indirizzo pubblico tramite il NAT, che tiene traccia delle connessioni attive e mappa le richieste di ritorno ai dispositivi interni appropriati.

IPv6 e l'Eliminazione della Necessità di NAT

Con **IPv6**, non c'è più il problema della carenza di indirizzi IP, perché il numero di indirizzi disponibili è praticamente illimitato. Ogni dispositivo sulla rete può avere il

suo indirizzo IP pubblico univoco, senza necessità di NAT. Questo dovrebbe semplificare la gestione della rete e migliorare le prestazioni. La transizione da IPv4 a IPv6 è però lenta a causa della compatibilità con le infrastrutture esistenti che utilizzano IPv4.



La **mancanza di NAT in IPv6** elimina la necessità di tradurre gli indirizzi IP e le porte, riducendo così la complessità della rete e migliorando la sicurezza, poiché non esiste la possibilità di "nascondere" i dispositivi dietro un indirizzo IP pubblico condiviso.

Intrusion Prevention e Egress Filtering

Intrusion Prevention (IPS)

L'**Intrusion Prevention System (IPS)** è una tecnologia utilizzata dai firewall per **prevenire attacchi in tempo reale** analizzando e bloccando le connessioni che presentano comportamenti sospetti o dannosi. L'IPS è in grado di monitorare il traffico di rete e rilevare attività che corrispondono a schemi conosciuti di attacco. Se una connessione viene riconosciuta come una minaccia, il firewall può interromperla, evitando che l'attacco abbia successo.

- **Rilevazione di attacchi:** L'IPS è in grado di rilevare attacchi in tempo reale come **buffer overflow**, **SQL injection**, **attacchi DoS/DDoS**, e altro.
- **Prevenzione automatica:** A differenza di un sistema di rilevazione che solo segnala gli attacchi, l'IPS prende provvedimenti attivi per fermare l'attacco, come l'interruzione della connessione compromessa.

Egress Filtering

L'**egress filtering** è una tecnica che si concentra sul controllo del traffico in uscita da una rete, in opposizione all'ingress filtering che si occupa di monitorare il traffico in ingresso.

L'egress filtering è particolarmente utile per:

1. **Rilevare e fermare le botnet**: Se un dispositivo all'interno della rete viene compromesso e diventa parte di una botnet, l'egress filtering può rilevare e bloccare il traffico che tenta di connettersi a server di comando e controllo esterni.
2. **Prevenire l'esfiltrazione di dati**: Si può configurare il firewall per limitare l'uscita di dati sensibili da parte di dispositivi non autorizzati o da software malevoli.
3. **Identificare errori di programmazione**: A volte i dispositivi interni possono inviare dati in uscita per errore o a causa di vulnerabilità nel software. L'egress filtering aiuta a rilevare questi problemi e ad impedirne la propagazione.

Benefici dell'Egress Filtering

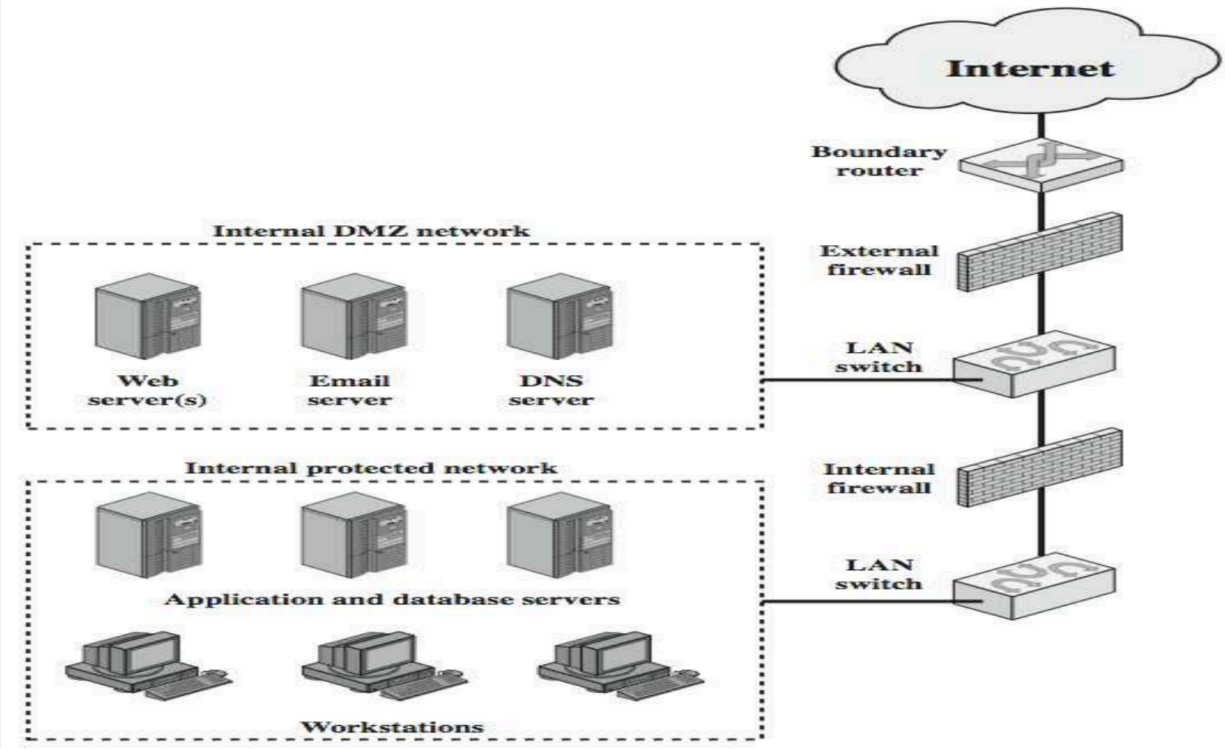
- **Prevenzione delle botnet e degli attacchi DDoS:** Evita che dispositivi compromessi possano comunicare con server esterni per lanciare attacchi DDoS o partecipare a botnet.
- **Controllo del traffico in uscita:** Limita la possibilità che dati sensibili vengano esfiltrati o che software malevoli possano comunicare con attaccanti esterni.
- **Miglioramento della sicurezza**: Rende più difficile per gli attaccanti che hanno compromesso un sistema di esfiltrare informazioni o inviare comandi ad altri dispositivi infetti.

Best Practices per l'Egress Filtering

- **Filtri anti-spoofing**: Proteggere la rete impedendo pacchetti con indirizzi IP falsificati (spoofed) di lasciare la rete. Gli attacchi DoS e DDoS spesso si basano su questo tipo di tecnica per mascherare la loro origine.
- **Limitare il traffico in uscita a indirizzi IP autorizzati**: Questo assicura che solo il traffico proveniente da dispositivi e applicazioni autorizzati possa uscire dalla rete.
- **Blocco di servizi non necessari**: Alcuni servizi, come **NetBIOS**, **TFTP**, **SMB**, e **IRC**, sono noti per essere utilizzati in attività malevoli. Questi dovrebbero essere bloccati in uscita se non necessari.
- **Limitare i servizi a pochi host**: I servizi critici come DNS, SMTP, e HTTP dovrebbero essere limitati solo a determinate macchine (come i server), per evitare che un dispositivo compromesso possa inviare traffico non autorizzato.

Architettura del Firewall

Esistono diverse configurazioni e architetture per l'implementazione di firewall in una rete aziendale. Due delle architetture più comuni sono **Screening Router + Bastion Host** e **Layered Defence (Defence in Depth)**.



Screening Router + Bastion Host

Questa architettura è utilizzata per proteggere la rete da attacchi esterni, combinando un router di screening con un **bastion host**.

- **Router di Screening**: Il router si trova tra la rete interna e quella esterna (Internet) e filtra il traffico in base a determinate regole (per esempio, ACL su indirizzi IP). È utilizzato per bloccare il traffico non desiderato prima che raggiunga il bastion host.
- **Bastion Host**: Questo è un sistema che si trova in una zona esposta, come una DMZ (Demilitarized Zone). Viene utilizzato come punto di accesso sicuro per i servizi esterni, come il web server o il mail server, che devono essere raggiungibili da Internet. Il bastion host è progettato per resistere agli attacchi e di solito è configurato con una sicurezza elevata.

Layered Defence (Defence in Depth)

La **difesa in profondità** è un approccio di sicurezza che implementa più livelli di protezione, per ridurre la probabilità che una singola vulnerabilità comprometta l'intera rete.

- **Router**: I router proteggono la rete filtrando il traffico a livello IP e utilizzando ACL (Access Control List) per definire quali pacchetti sono ammessi.
- **Switch**: Gli switch operano a livello 2 (Data Link Layer) e sono utilizzati per connessioni veloci tra nodi all'interno della stessa rete. Possono essere configurati con ACL basate su indirizzi MAC per limitare l'accesso alla rete interna.

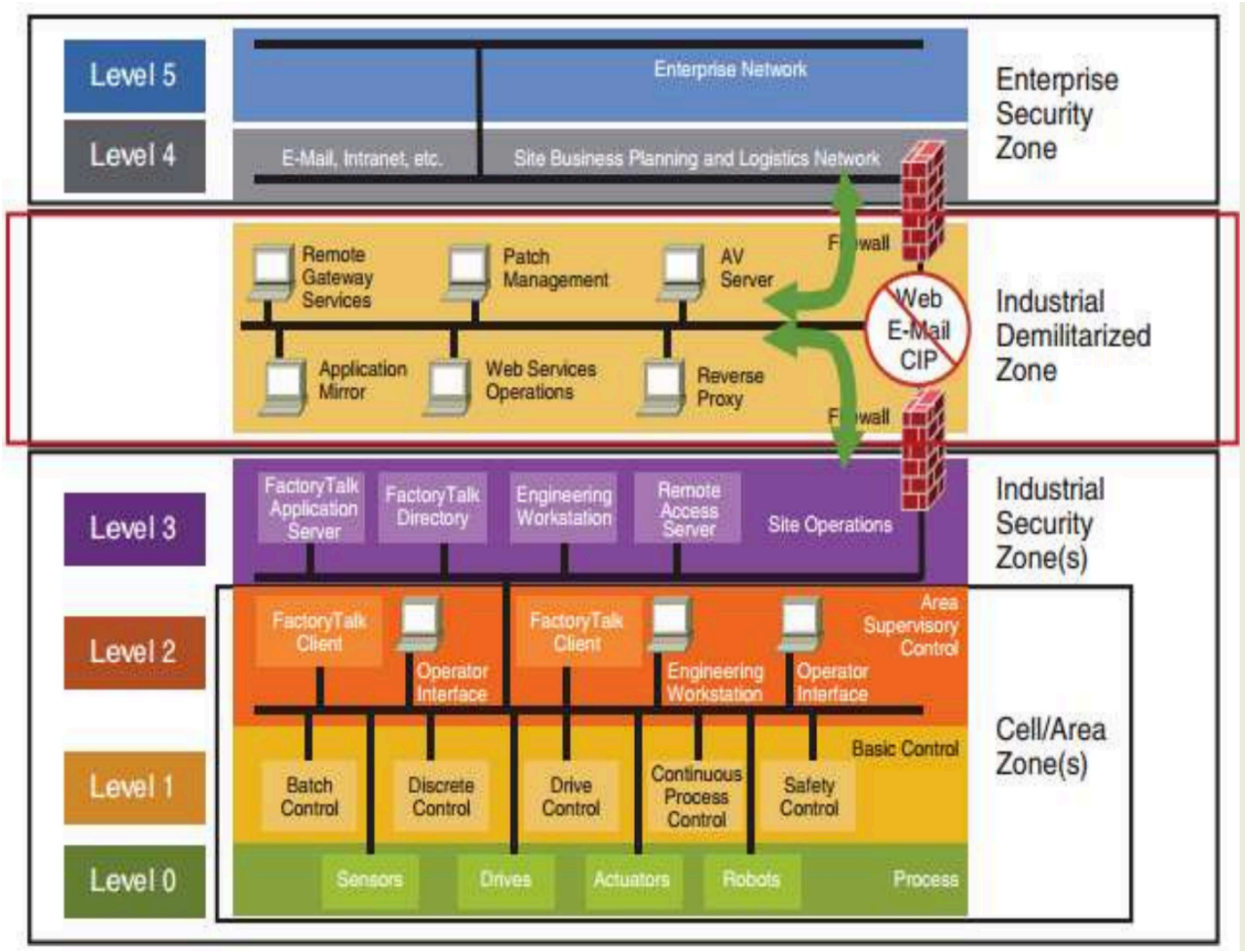
In un'architettura a **difesa in profondità**, un attaccante deve superare più livelli di protezione per riuscire a compromettere la rete, il che aumenta la sicurezza complessiva.

Uso di Firewall in Modelli Specifici

ICS - Purdue Model

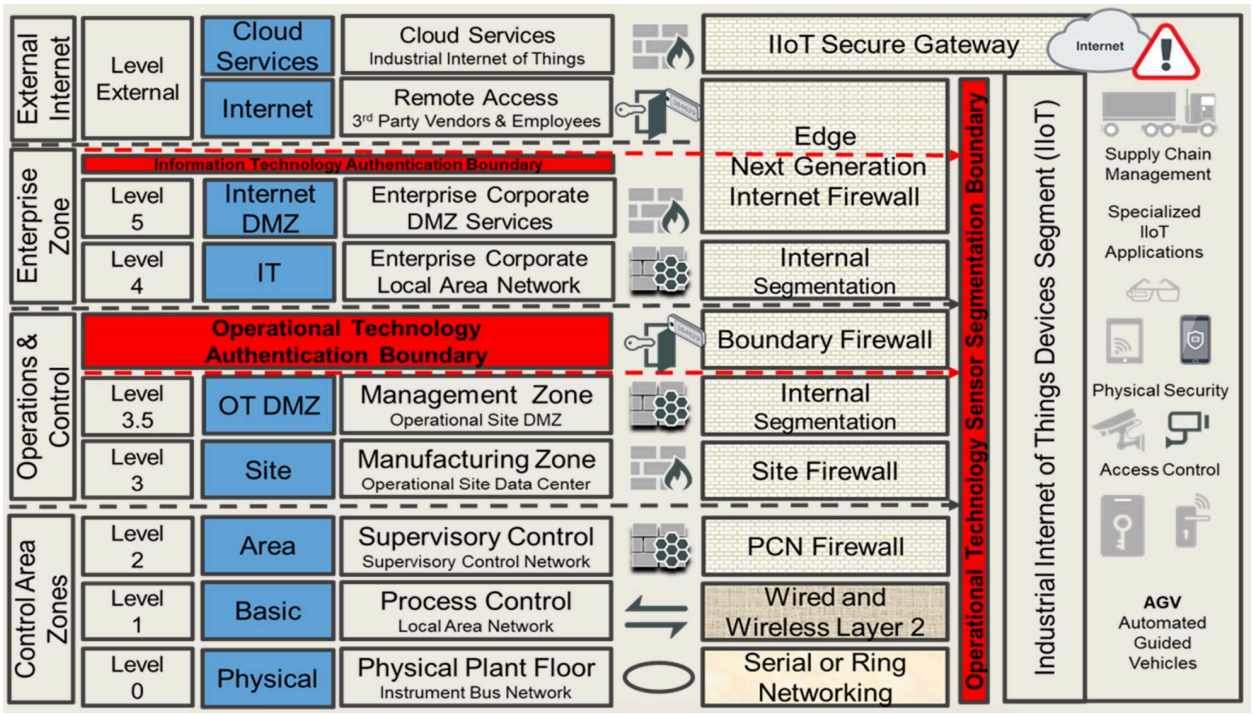
Nel **Purdue Model**, utilizzato nelle architetture di controllo industriale (ICS), i firewall sono fondamentali per proteggere i sistemi di controllo da attacchi esterni. I firewall monitorano e filtrano il traffico tra le diverse zone della rete (es. DMZ,

rete di controllo, e rete di monitoraggio). In questo contesto, l'isolamento e il controllo rigoroso del traffico in ingresso e in uscita sono essenziali per prevenire compromissioni.



Uso di Firewall in ICT + IoT

Nel contesto di **ICT** e **IoT**, i firewall sono necessari per proteggere i dispositivi IoT che, a causa delle loro risorse limitate, sono spesso vulnerabili agli attacchi. L'implementazione di firewall a livello di rete e dispositivo è cruciale per garantire che solo i dispositivi autorizzati possano comunicare tra loro e con l'esterno. Inoltre, i firewall possono prevenire che dispositivi IoT compromessi possano esfiltrare dati o ricevere comandi da attaccanti esterni.


External Internet
Level External
Cloud Services
Cloud Services
Industrial Internet of Things
Internet
Remote Access
3rd Party Vendors & Employees
IIoT Secure Gateway
Internet
Edge
Next Generation
Internet Firewall
Information Technology Authentication Boundary
Enterprise Zone
Level 5
Internet DMZ
Enterprise Corporate
DMZ Services
Level 4
IT
Enterprise Corporate
Local Area Network
Internal
Segmentation
Operations & Control
Operational Technology
Authentication Boundary
Boundary Firewall
Level 3.5
OT DMZ
Management Zone
Operational Site DMZ
Internal
Segmentation
Level 3
Site
Manufacturing Zone
Operational Site Data Center
Site Firewall
Control Area Zones
Level 2
Area
Supervisory Control
Supervisory Control Network
PCN Firewall
Level 1
Basic
Process Control
Local Area Network
Wired and
Wireless Layer 2
Level 0
Physical
Physical Plant Floor
Instrument Bus Network
Serial or Ring
Networking
Operational Technology Sensor Segmentation Boundary
Industrial Internet of Things Devices Segment (IIoT)
Supply Chain
Management
Specialized
IIoT
Applications
Physical Security
Access Control
AGV
Automated
Guided
Vehicles